

13 Practices to Help Improve Your Open Source Legal Compliance

13 Practices to Help Improve Your Open Source Legal Compliance

Created on 2021-08-03 13:55

Published on 2021-08-03 17:34

This post offers general recommendations related to open source compliance practices. For a detailed discussion on building and managing open source compliance programs please refer to the resources section at the end of this post. It is important to know that every organization is different, has their own custom policy, guidelines and processes. Therefore, it is expected that some of these recommendations may not exactly fit your current compliance framework but can be used as possible ideas for improvements.

1. Identify all Source Code

Software enters an organization via three main sources: source code introduced by an organization's own developers, source code coming via third party commercial software providers, and open source channels such as GitHub. It is recommended that all source code used in any given product or service go through the compliance process in which an organization is able to identify the origin and license of the source code and set up a plan to meet the obligations of all applicable licenses.

2. Establish a Recurring Scanning Model

Organizations adopt various methods to manage approvals to use open source. The tendency has been to be as efficient as possible with these approvals given the massive adoption of open source software. Some organizations require developers to request a formal approval to use open source code and are only allowed to check in the code into the product repo once approval is granted. In some cases, developers, in the rush of getting work done, may not issue a compliance ticket to request approval to use the needed open source code. Therefore, it is

critical to have an additional checkpoint or a method that captures unapproved open source code that is entering the software stack. This situation can be resolved by running regular full scans for the full software stack every x weeks (depending on the speed of development) and identifying components that don't have a corresponding compliance ticket. A new compliance ticket will then be created per component and pushed via the normal compliance verification process.

3. Verify Compliance on a Case-by-Case Basis

Approving the use of open source software in one case does not necessarily serve for all cases. Compliance issues may arise depending on the context of use of a specific component and how it interacts with other components licensed under different licenses (open source or proprietary). It is recommended that each time developers modify a previously approved open source component or plan to use a previously approved component, a new scan is run. The result will be a new bill of material, a confirmation of licenses, and an approval of use in the new context.

4. Verify Licenses When Upgrading Versions of Open Source Components

License changes in open source components may occur between major version upgrades. When developers upgrade versions of open source components, it is recommended that they verify the license. If there is a change in the license, a new compliance ticket may need to be created requesting approval to use the new version of the open source component licensed now under a different license.

5. Resolve Compliance Issues Flagged by Software Composition Analysis Tools

When a source code scanner is run on the code base, the output may include certain flags pointing to possible issues as identified based on the rules and policies configured in the SCA tool. When these flags are confirmed as a real issue, it is recommended to work with the developers to resolve the issue, run a new scan after the resolution, and generate a new bill of material based on the updated source code.

6. Save all Licensing Information

In preparation for the legal review in relation to the use of open source components, it is recommended to save all related licensing information such as COPYING, README, or LICENSE files available in the repo. Many organizations require that such files are attached to the compliance ticket of the specific

open source component to provide reviewers of the ticket all the information needed to make a proper evaluation of the compliance status.

7. Maintain a Record of Discussion

Following on the previous practice (saving licensing information), it is recommended to maintain a summary of discussions in the compliance ticket that lead to the approval or rejection of a specific open source component. Such documentation can prove very useful when attempting to determine the basis on which approval for a specific component was granted and how possible issues were resolved.

8. Provide a Written Offer

The written offer is an essential building block of a successful compliance effort. Certain open source licenses require that the recipients of the software are notified of various license information and have access to the source code. It is recommended to use clear language and be inclusive of all open source software included in the product or service. Organizations often try to make it easy to locate this information (written offer and open source licensing information) on the product itself, in the product documentation, and/or on a website (the location varies depending on the product or service).

9. Manage Modifications to Open Source Software

It is recommended that all modifications to open source code is captured in the revision history (change log file). When redistributing modified code, depending on the license in effect, your modifications need to be clearly marked as such. Some companies elect a different and a more efficient approach by providing the original open source code along with the company's contributed patch file that applies against the original open source package. Following this approach, the company's modifications are clearly separated and identifiable from the original open source package.

10. Pay Attention to Retired Components

In some instances, a previously approved open source component may no longer be in use anymore. When faced with such a scenario, it is recommended that developers re-open the corresponding compliance ticket and update it to reflect that the component has been retired with details in relation to the build number and specific use information. This action will trigger the update of the open source license information provided to the users of the product or service.

11. Avoid Copy/Paste

Developers must avoid copying and pasting open source code into proprietary or third party source code (or vice versa) without prior documented approval. Such actions can have serious implications on license compliance.

12. Avoid Mixing Source Code with Different Licenses

Following the previous note on avoiding copy/paste without approval, it is recommended to avoid mixing code incoming under different licenses without proper approval. Some open source licenses are incompatible with one another and many are not compatible with proprietary licenses. It is therefore highly recommended to seek support from your legal counsel and receive approval to mix source code licensed under different licenses.

13. Preserve Original License Information

It is highly recommended not to remove or in any way disturb existing copyrights, attribution and licensing information in any open source component.

Closing

It is widely acknowledged that open source is a great vehicle for innovation allowing organizations to share R&D efforts and build common and enabling base technologies. There is, however, the obligation of being respectful to the licenses under which open source is released. In this post, we shared some practices in relation to ensuring license compliance when using open source in products or services. We hope you find it useful and helpful to your compliance efforts. Thank you for reading!

Resources

1. An Open Guide to Evaluating Software Composition Tools (11/2020)
2. **Recommended Open Source Compliance Practices for the Enterprise** (04/2019)
3. **Assessment of Open Source Practices as Part of M&A Transaction Due Diligence** (03/2019)
4. **Open Source Compliance in the Enterprise, 2nd Ed.** (12/2018)
5. **Enterprise Open Source: A Practical Introduction** (08/2018)
6. **Open Source AI: Projects, Insights and Trends** (05/2018)
7. **Open Source Audits in Merger and Acquisition Transactions** (Also available in **Japanese** - 02/2018)

Disclaimer

I am not a counsel and nothing in this post can be considered legal advice. This post represents my own opinions and not those of my current or any of my

previous employers.